

AdvocateAuroraHealth

Title: AAH Health Informatics & Technology Disaster Recovery		Document Number: 2432
Document Type: ☒ Policy ☐ Procedure ☐ Guideline ☐ Other		Last Review/Revision Date: 09/13/2021
Content Applies to Patient Care: (Select all that apply) ☐ Adults ☐ Pediatrics (Under 18)	Content Applies to: (Select One) ☐ Clinical ☒ Administrative	Next Review Date: 09/13/2024
		Effective Date: 09/13/2021
Scope: ☒ AAH System ☐ ACH ☐ AAH IL Only ☐ AAH WI Only ☐ Site Only (Location Name): ☐ Department Only (Department Name):		

I. PURPOSE

It is the policy of Advocate Aurora Health (AAH) to create and maintain plans, processes, procedures, and technology to enable the continuation of critical business and Health Informatics and Technology (HIT) processes and systems in the event of an extended system outage, disaster, or other business disrupting event.

This policy will work in tandem with the Advocate Aurora Business Continuity Policy prioritizing application, infrastructure and data recovery based on the department Business Impact Analysis (BIA).

II. SCOPE

This policy applies to all AAH team members and third parties who interact with data and applications residing on systems, networks, and hosted in AAH Data Centers, hosted by third parties, and located with providers of Cloud Computing Services that must account for HIT disaster recovery.

III. DEFINITIONS/ABBREVIATIONS

Third-Party Hosted Applications: Applications which AAH has contracted for and hosted off-premise by a third- party vendor.

Cloud Computing: the practice of using a network of remote servers hosted on the internet to store, manage, and process data, rather than a local server or a personal computer.

Cloud Computing Services Platform Types:

- **Infrastructure as a Service (IaaS):** Allows for ability to configure and manage the hardware for your application and is most flexible cloud service.
- **Platform as a Service (PaaS):** The platform management is handled by the cloud provider and the focus is on the application development.
- **Software as a Service (SaaS):** Users pay for the software as they use it on a subscription model; a pay-as-you-go pricing model.

Business Continuity (BC): The strategic and tactical capability of the organization to plan for and respond to incidents and business disruptions in order to continue business operations at an acceptable predefined level.

Disaster Recovery (DR): The process, policies and procedures related to preparing for recovery or continuation of technology infrastructure, systems and applications which are vital to an organization after a disaster or outage.

DR Exercise: A people, process and technology focused activity designed to execute DRP's and evaluate the results against an approved set of standards and objectives. Exercises are performed for the purpose of training team members and validating recoverability with the purpose of continuous improvement.

DR Gap: An identified risk to achieving the business application recoverability requirements per the assigned HIT Disaster Recovery Tier.

DR Plan (DRP): Management approved document that defines the resources, actions, tasks, and data required to manage the technology recovery effort.

DR Tiers: (described in the HIT Disaster Recovery Tiers Standard) – Tiers which define the time HIT must recover an application or system before business is being negatively impacted and downtime procedures are no longer practical.

DR Exercise Types:

- **Non-Functional:** "Tabletop"
- **Partial-Functional:** "Simulation" or "VM Bubble"
- **Full-functional:** "Operational", "Flip", or "Flip and Abort"

Health Informatics and Technology (HIT): Health Informatics and Technology Department

SOC 2 Type 2 report: An internal controls report capturing how a company safeguards customer data and how well those controls are operating. These reports are issued by independent third-party auditors covering the principles of Security, Availability, Confidentiality, and Privacy.

IV. POLICY

A. DR Tiers

1. Disaster Recovery tiers must be assigned to applications and are determined by a risk analysis
2. Business System Owner and HIT Tech Owner leadership (director or above) can decide to override the tier determination of the risk analysis process but must provide a documented rationale.
3. AAH, third-party hosted, and Cloud Computing Services platform applications must be architected to adhere to placement within the HIT Disaster Recovery Tiers Standard.

B. DR Plans

1. HIT must create and maintain DRP's and the associated procedures for recovering and exercising for all AAH hosted applications.
2. AAH hosted tier 1-3 application DRP's must be reviewed and updated as needed on an annual basis.
3. The DRP must be approved by a HIT Application Owner (director or above).
4. Tier 1 applications hosted by AAH third-party vendors and Cloud Computing Services providers must provide evidence of a DRP and DR exercise, or provide documentation of a regulatory report (e.g. SOC 2 Type 2 report,)

C. DR Exercises

1. Tier 1 applications hosted by AAH or on a Cloud Computing Services Platform must be exercised on an annual basis to validate if the recoverability requirements per the assigned HIT Disaster Recovery Tier can be met.
2. SaaS environments would be dependent upon the AAH and vendor contract requirements
3. Tier 1 applications hosted by AAH third-party vendors must provide evidence of conducting an annual disaster recovery exercise to validate if the recoverability requirements per the assigned HIT Disaster Recovery Tier can be met.
4. A DR exercise of a new application must be executed prior to production implementation.

5. All Tier 1-3 business applications with disaster recovery gaps will be added to the Contingency Planning section of the AAH Risk Registry.
6. A DR exercise will be conducted for select Tier 2-4 applications as determined by HIT Technology Leadership.

V. PROCEDURES

N/A

VI. CROSS REFERENCES

- A. AAH Business Continuity Policy
- B. HIT Disaster Recovery Tiers Standard

VII. RESOURCES AND REFERENCES

HIPAA Security Rule 164.308 (a) (7) (i)

NIST 800-53r5 CP-2, CP-4, CP-9, CP-10

CIS 11 Data Recovery

PCI DSS 3.2.1 11.1.2, 12.5.3, 12.10

HITRUST CSF v9.4

NFPA 1600 Standard on Disaster/Emergency Management and Business Continuity/Continuity of Operations Program